

Dual-Use Cybersecurity AI Accountability Act (DUCAA): A Policy Framework for Ethical AI Governance in Cybersecurity

Author: Usha Priya Krishnasamy, Boston University

Date: December 2025

Problem Identification:

One of the major changes made by artificial intelligence in the field of cybersecurity is the use of AI-based defensive systems which helps in detecting complex threats, automating the response process, and predicting the future threat through analysis of data. Still, these defensive AI systems result in an unsettling ethical paradox: essentially tools designed to safeguard can be weaponized by adversaries; we are trying to eliminate. The August 2025 Workday breach shows this dual-use crisis. Cybercriminal groups in ShinyHunters and Scattered Spider exploited AI-powered OAuth authentication systems through social engineering, compromising data from over 700 organizations serving 70 million users. Despite employing advanced machine learning for behavioral analytics, Workday's AI security failed because attackers mimicked legitimate administrative actions.

This has never been the case. SolarWinds attack (2020) was a massive breach that led to compromise of more than 18,000 entities and included the insertion of a malicious code in the trusted software updates. The ransomware attack on Colonial Pipeline (2021) forced the fuel shortage that spread over the whole nation. These cases indicate a lack of governance, transparency, and accountability which are deep rooted in the system and cannot be fixed by technology alone.

Here, **Virtue ethics** offers the most appropriate framework, focusing on organizational character traits: transparency, accountability, prudence, and continuous ethical reflection. DUCAA builds on this by creating practices that foster ethical cultures, mandatory audits encourage prudence, documentation promotes transparency, and continuous assessments maintain moral responsibility. From a **Utilitarian** view, DUCAA's regulations make sense. Current practices prioritize innovation speed over comprehensive risk assessment, creating greater aggregate harm through massive breaches affecting millions. **Deontological ethics** reminds us that organizations have duties to protect user data and maintain system integrity regardless of consequences. **Contract theory** suggests stakeholders deserve informed consent about how AI systems handle their data, about how AI handles their data, but AI opacity prevents meaningful consent.

Research & Use of Sources:

This policy framework is based on a lot of real cybersecurity incidents including Workday breach 2025, SolarWinds 2020, Colonial Pipeline 2021, Snowflake 2024, MGM Resorts 2023, alongside regulatory frameworks (EU AI Act 2024, NIST AI RMF, H.R. 3369). These sources disclose the same disturbing trend that voluntary compliance is nearly unsuccessful if the case is that profits are put forth before security. They include international governance models (Singapore's Model AI Governance, Canada's Directive on Automated Decision-Making, UK's National AI Strategy) prove self-regulation fails. MacIntyre's virtue ethics, Singer's utilitarianism, and Kant's deontological theory provide philosophical grounding. Floridi and Vallor's technology ethics directly shaped DUCAA's character-based approach.

Technical standards from CISA, NIST, and NATO establish baselines. AAI, IEEE, and ISC2 reveal gaps DUCAA fixes.

Primary Stakeholders:

Organizations Implementing AI Systems: Entities such as Workday, government bodies, healthcare providers, and financial institutions are the main accountable ones. The revelation of the sensitive data of more than 700 organizations due to the Workday incident shows how the failure of one can have a cascading effect across ecosystems. DUCAA gives these organizations clear standards while protecting those who comply with them.

Employees and End Users: Seventy million users lost control of their data in Workday breach through phishing attacks. The transparency rules set by DUCAA enable individuals to identify fake requests. However, conflicts are still there: while companies crave speed, users demand safety, vendors keep secrets, and regulators insist on transparency.

IT and Security Professionals: The Workday incident revealed how AI heuristics failed against socially engineered anomalies. DUCAA's continuous audit requirements and dual-use assessments provide frameworks to identify tool weaponization before deployment.

Secondary Stakeholders:

Regulatory Bodies: Such agencies as CISA, NIST, and the FBI coordinate to give cybersecurity responses but do not have detailed frameworks for AI management. DUCAA establishes standard criteria that make it easier for consistent supervision.

AI Developers and Vendors: Third-party providers like Salesloft unintentionally create supply chain vulnerabilities. DUCAA's vendor accountability provisions require contractual safeguards that align developer incentives with security outcomes.

Society and Critical Infrastructure: The Colonial Pipeline attack is a case of how a cybersecurity breach can cause a chain of events that extend beyond the immediate victims. Insurance companies and lawyers have to deal with more complicated liability issues in the case of AI security failures. Clear rules of the DUCAA simplify their work.

Policy Advocacy & Feasibility:

The Dual-Use Cybersecurity AI Accountability Act is a detailed framework that regulates the use of AI in cybersecurity. This policy is realistic because it uses agencies and budgets that already exist. On the federal level, the legislation by the U.S. Congress makes it compulsory while the regulatory agencies (NIST, CISA) set up technical standards and ensure the enforcement using their current powers and funds, and industry bodies establish best practices.

Core Policy Requirements:

1. Transparent Documentation and Logging: It is the responsibility of the organizations to ensure exhaustive logs of AI system actions covering decision-making processes, data sources, model updates, and access patterns. For this purpose, NIST-standardized logging formats, secure storage, and at least a minimum of five-year retention periods are necessary.

2. Pre-Deployment Ethical Audits: Ethical audits from a third party are needed before any AI deployment in cybersecurity roles, evaluating its dual-use and misuse potential. These audits evaluate whether threat detection algorithms could be reverse engineered, the possibility of behavioral analytics being bypassed, and social engineering resistance in authentication systems.

3. Restricted Algorithm Access: Only verified personnel with multi-factor authentication and need-to-know principles should have access to sensitive AI algorithms, model architectures, and training data. Organizations are required to put into effect zero-trust architectures that call for continuous identity verification.

4. Dual-Use Risk Assessments: The organization should be making quarterly evaluations of the ways in which AI defensive tools might be turned against them by offensive use through red team exercises, scenario planning, and continuous monitoring for new attack vectors.

5. Vendor Accountability and Supply Chain Security: Third-party vendors providing AI-integrated tools must meet the same DUCAA standards as the internal units. Agreements should specifically restrict the data access rights, forbid unauthorized data sharing, and establish joint liability for security breaches.

6. Mandatory Multi-Factor Authentication: All OAuth connections, API integrations, and admin access must be secured with MFA which should combine knowledge, possession, and biometric factors and use phishing-resistant methods like FIDO2 security keys.

DUCAA forms a Cybersecurity AI Ethics Board within CISA with experts in AI, ethics, cybersecurity, and law. This board actively reviews audit reports, investigates incidents, issues compliance guidance, and imposes penalties between 2-4% of yearly revenue for serious violations, escalating to system shutdowns. Board members serve staggered terms preventing industry takeover. Organizations are classified by risk tier:

- **Tier 1** (critical infrastructure, systems serving 10+ million users): annual audits,
- **Tier 2** (mid-size organizations): audits every two years
- **Tier 3** (startups, small businesses): gradual rollout with grant programs.

The **EU AI Act (2024)** creates risk-based requirements for high-risk systems and does not provide the specifics for cybersecurity dual-use situations. DUCAA borrows the AI Act's risk-based framework while adding cybersecurity-specific requirements. **NIST's AI Risk Management Framework** offers voluntary guidance, but voluntary approaches haven't worked. Workday breach occurred despite available NIST guidance. DUCAA makes core NIST principles mandatory. The proposed **federal AI Accountability Act (H.R. 3369)** requires impact assessments for automated decision systems. DUCAA adopts this assessment approach but focuses on cybersecurity applications where dual-use risks are sharp. **Corporate AI ethics policies** from major tech companies show industry awareness of AI risks but suffer from voluntary adoption and limited external oversight. DUCAA establishes mandatory baseline standards ensuring industry-wide consistency. **International approaches** including Singapore's Model AI Governance Framework (advisory), Canada's Directive on Automated Decision-Making (government-specific), and the UK's National AI Strategy (light-touch regulation) reveal

that complete self-regulation is ineffective. DUCAA strikes balance through risk-based requirements and phased implementation.

Critique & Unintended Consequences

Critique 1: Innovation Burden and Competitive Disadvantage:

The Critique: Technology companies will say DUCAA's requirements slow development cycles and impose costs that reduce competitiveness. Startups may struggle with compliance expenses, potentially consolidating markets around large players.

Response: This assumes ethics and innovation oppose each other, but evidence shows ethical governance enhances long-term competitiveness. Workday breach caused damage to reputation across 700+ client organizations, with remediation costs far exceeding any compliance investment. DUCAA includes startup exemptions for organizations with fewer than 50 employees or in their first three years to receive technical assistance grants, extended timelines, and shared audit program access. The policy creates market advantage for ethical actors by establishing leveling the fields. International coordination through existing Five Eyes and NATO frameworks can extend standards globally, preventing regulatory arbitrage.

Critique 2: Information Security and Adversary Intelligence:

The Critique: Documentation and transparency might give adversaries intelligence about our defenses. Security through obscurity offers some protection DUCAA would remove.

Response: DUCAA carefully balances transparency with operational security through tiered disclosure. Audit reports submitted to regulators stay confidential with classified handling

protocols. Public disclosures describe system capabilities at a high level without revealing implementation details. Security through obscurity is illusory; the SolarWinds and Workday breaches succeeded despite proprietary closed systems. DUCAA in fact enhances security as it necessitates that companies discover and patch security loopholes via red teaming, rather than waiting for the adversaries to find them

Critique 3: Enforcement Gaps and International Coordination:

The Critique: DUCAA limits its scope to organizations based in the U.S. only, thus posing difficulties for supply chains that are global and threats that are international, emanating from areas that do not comply with regulations.

Response: The vendor accountability measures in DUCAA extend the requirements to any third party integrated into U.S. systems. A foreign vendor will have to comply with DUCAA standards to access the U.S. market, creating economic incentive for global compliance. DUCAA authorizes the Cybersecurity AI Ethics Board to establish mutual recognition agreements with foreign regulators meeting equivalent standards, like GDPR adequacy determinations. The EU AI Act provides parallel governance in Europe, and U.S. - EU coordination approaches can create de facto global standards.

Critique 4: Technology Moves Too Fast:

The Critique: AI is changing so fast that what is required for technology today becomes outdated very quickly, thus new gaps are left, or unnecessary restrictions are created.

Response: DUCAA focuses on principles like transparency and accountability rather than specific technologies. The Ethics Board reassesses every six months, updating guidance without waiting for Congress. NIST keeps technical standards current with emerging threats. Outside auditors check whether security improved, not whether boxes got checked. The Board fires auditors who rubber stamp approvals. Companies stay liable even when compliant, emphasizing real protection over paperwork.

Clarity & Organization-Implementation Timeline:

Year 1 - Foundation: Congressional passage of DUCAA, establishment of Cybersecurity AI Ethics Board, development of technical standards by NIST, creation of auditor certification program, and stakeholder education campaigns.

Year 2 - Pilot Phase: Voluntary early adoption by critical infrastructure operators, pilot audits of major cybersecurity AI systems, refinement of standards based on implementation experience.

Year 3 - Mandatory Compliance: Full DUCAA requirements take effect for Tier 1 organizations, streamlined compliance pathways for Tier 2 organizations, continued exemptions with technical assistance for Tier 3 startups.

Years 4-5 - Expansion and Refinement: Extension to Tier 2 mandatory compliance, international coordination agreements, assessment of policy effectiveness, potential expansion to additional AI domains.

Policy's effectiveness will be evaluated through reduction in successful breaches of compliant systems compared to historical baselines, increased detection of dual-use vulnerabilities during pre-deployment audits, improved stakeholder trust measured through periodic surveys, industry adoption of ethical practices exceeding minimum requirements, and reduced incident detection time. The Ethics Board will disseminate yearly reports that include incident data without any personal identifiers.

Conclusion:

The dual-use dilemma in cybersecurity is going to become more severe with the AI development and the adversaries' sophistication. Companies, policymakers, and cybersecurity professionals should already be thinking about ethical regulation because they do not have the luxury of time; Their main priority must be to avoid the rupture of public trust as a result of disastrous failures. DUCAA provides the framework for such regulation, balancing innovation with accountability, security with transparency, and the needs of individual organizations with the interests of the society as a whole. Employing virtue ethics as the mainstay while allowing for utilitarian and deontological elements, DUCAA provides thorough ethical coverage. DUCAA changes the dual-use issue that threatens the very existence of the concept of virtue ethics into a manageable problem by stipulating that virtue ethics be enforced, not optionally practiced. With the rise of AI, which is becoming increasingly powerful, the need for a response to the situation after the fact is replaced by that of governance which is flexible and capable of foreseeing the developments with a view to ensuring that the tools for our defense are actual defenders and do not open up new vulnerabilities.

References

Bloomberg. (2021, May 8). *U.S.'s biggest gasoline pipeline halted after cyberattack*. Bloomberg.

<https://www.bloomberg.com/news/articles/2021-05-08/u-s-s-biggest-gasoline-and-pipeline-halted-after-cyberattack>

Bloomberg. (2023, september 15). *How a hacker group used vishing to breach MGM Resorts*.

Bloomberg. <https://www.bloomberg.com/news/articles/2023-09-16/mgm-resorts-hackers-broke-in-after-tricking-it-service-desk>

Cybersecurity Dive. (2025, August 18). *Hackers target Workday in social engineering attack*.

Cybersecurity Dive.

<https://www.cybersecuritydive.com/news/hackers-target-workday-in-social-engineering-attack/758095/>

Cybersecurity & Infrastructure Security Agency (CISA). (2023, May 7). *The attack on Colonial Pipeline: What we've learned & what we've done over the past two years*. CISA.

<https://www.cisa.gov/news-events/news/attack-colonial-pipeline-what-weve-learned-what-weve-done-over-past-two-years>

DoControl. (2025, August 22). *Workday breach: What happened and what we can learn*.

DoControl blog.

<https://www.docontrol.io/blog/workday-breach>

MacIntyre, A. (1981). *After virtue: A study in moral theory*. University of Notre Dame Press.

European Union. (2024). *Regulation (EU) 2024/1689 on harmonised rules on artificial intelligence*. EUR-Lex.

https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=OJ:L_202401689

H.R. 3369 – Artificial Intelligence Accountability Act. (2023, May 16). Congress.gov.

<https://www.congress.gov/bill/118th-congress/house-bill/3369>

ISC2. (2024, January 24)

<https://www.isc2.org/Insights/2024/01/The-Ethical-Dilemmas-of-AI-in-Cybersecurity>.

ISC2.

Lee, G. (2025, August 25). *Ethical and regulatory challenges in AI-driven cybersecurity*. Daily Security Review.

<https://dailysecurityreview.com/cyber-security/ethical-and-regulatory-challenges-in-ai-driven-cybersecurity/>

Obsidian Security. (2025, August 25). *ShinyHunters and Scattered Spider: A merger of chaos*. Obsidian Security Blog.

<https://www.obsidiansecurity.com/blog/shinyhunters-and-scattered-spider-a-merger-of-chaos-in-the-2025-salesforce-attacks>

Reuters. (2020, December 14). *SolarWinds hack exposes multiple government agencies*. Reuters.

<https://www.reuters.com/article/technology/solarwinds-hack-was-largest-and-most-sophisticated-attack-ever-microsoft-pres-idUSKBN2AF03Q/>

Reuters. (2024, August 21). *Snowflake breach exposes data from major companies*. Reuters.

<https://www.reuters.com/technology/snowflake-raises-annual-product-revenue-forecast-2024-08-21/>

Soergel, A. (2021, May 10). *Colonial ransomware attack explainer*. CNN.

<https://edition.cnn.com/2021/05/10/politics/colonial-ransomware-attack-explainer>

TechCrunch. (2025, August 18). *HR giant Workday says hackers stole personal data*.

TechCrunch.

<https://techcrunch.com/2025/08/18/hr-giant-workday-says-hackers-stole-personal-data-in-recent-breach/>

Wassenaar Arrangement. (2024, December 3). *Export controls for dual-use goods and technologies*. The Wassenaar Arrangement.

<https://www.wassenaar.org/>

Workday. (2025, August 18). *Workday's response to Salesloft Drift security incident*. Workday Blog.

<https://blog.workday.com/en-us/workdays-response-salesloft-drift-security-incident.html>

Workday discloses data breach via third-party CRM. (2025, August 21). MLQ AI News.

<https://mlq.ai/news/workday-discloses-data-breach-via-third-party-crm-links-to-recent-salesforce-social-engineering-campaigns/>

Luciano Floridi. (2013). *The Ethics of Information*. Oxford University Press, Oxford (UK) / New York (US).

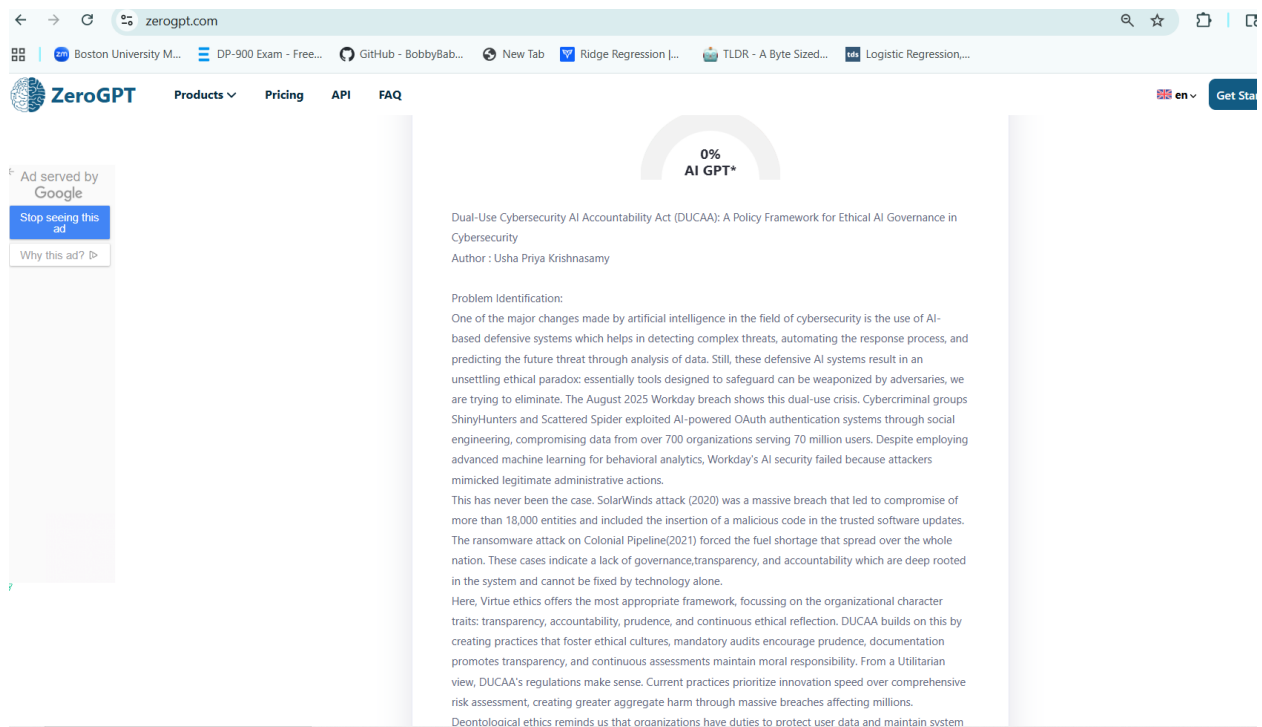
https://academic.oup.com/book/35378?utm_source=chatgpt.com&login=false

Shannon Vallor. (2016). *Technology and the Virtues: A Philosophical Guide to a Future Worth Wanting*. Oxford University Press, New York (and Oxford).

10.1093/acprof:oso/9780190498511.001.0001

Gen AI Appendix:

I have not used gen AI for this work



The screenshot shows a web browser displaying the ZeroGPT website. The browser's address bar shows "zerogpt.com". The website's header includes the ZeroGPT logo, navigation links for Products, Pricing, API, and FAQ, and a language selector set to "en". A sidebar on the left contains an ad served by Google with a "Stop seeing this ad" button and a link to "Why this ad?". The main content area features a large circular graphic with "0% AI GPT*" and a title "Dual-Use Cybersecurity AI Accountability Act (DUCAA): A Policy Framework for Ethical AI Governance in Cybersecurity" by Usha Priya Krishnasamy. The article text discusses the ethical challenges of AI in cybersecurity, citing incidents like the August 2025 Workday breach and the SolarWinds attack (2020). It argues for a framework based on virtue ethics, emphasizing transparency, accountability, and continuous ethical reflection. The article concludes by stating that deontological ethics reminds organizations of their duties to protect user data and maintain system integrity.

Ad served by Google
Stop seeing this ad
Why this ad? ➤

0%
AI GPT*

Dual-Use Cybersecurity AI Accountability Act (DUCAA): A Policy Framework for Ethical AI Governance in Cybersecurity
Author : Usha Priya Krishnasamy

Problem Identification:
One of the major changes made by artificial intelligence in the field of cybersecurity is the use of AI-based defensive systems which helps in detecting complex threats, automating the response process, and predicting the future threat through analysis of data. Still, these defensive AI systems result in an unsettling ethical paradox: essentially tools designed to safeguard can be weaponized by adversaries, we are trying to eliminate. The August 2025 Workday breach shows this dual-use crisis. Cybercriminal groups ShinyHunters and Scattered Spider exploited AI-powered OAuth authentication systems through social engineering, compromising data from over 700 organizations serving 70 million users. Despite employing advanced machine learning for behavioral analytics, Workday's AI security failed because attackers mimicked legitimate administrative actions.

This has never been the case. SolarWinds attack (2020) was a massive breach that led to compromise of more than 18,000 entities and included the insertion of a malicious code in the trusted software updates. The ransomware attack on Colonial Pipeline(2021) forced the fuel shortage that spread over the whole nation. These cases indicate a lack of governance,transparency, and accountability which are deep rooted in the system and cannot be fixed by technology alone.

Here, Virtue ethics offers the most appropriate framework, focussing on the organizational character traits: transparency, accountability, prudence, and continuous ethical reflection. DUCAA builds on this by creating practices that foster ethical cultures, mandatory audits encourage prudence, documentation promotes transparency, and continuous assessments maintain moral responsibility. From a Utilitarian view, DUCAA's regulations make sense. Current practices prioritize innovation speed over comprehensive risk assessment, creating greater aggregate harm through massive breaches affecting millions.

Deontological ethics reminds us that organizations have duties to protect user data and maintain system